E-Commerce Cloud Architecture on AWS

Technical Design Document – 3-Tier, Highly Available

1. Overview

This document describes a highly available, secure and scalable AWS architecture for an e-commerce application. The design uses a classic three-tier model (web, application and data tiers) deployed across two Availability Zones inside one VPC (10.0.0.0/16). Static content is delivered through CloudFront from S3, and the whole edge is protected by AWS WAF and AWS Shield.

Goals

- **High availability:** no single point of failure; every tier runs in two Availability Zones.
- **Scalability:** the application tier scales automatically with traffic (for example during sales).
- **Security:** private subnets for application and data, layered security groups, least-privilege IAM, edge protection.
- **Performance:** static assets are cached at CloudFront edge locations close to users.
- **Cost awareness:** managed services and auto scaling avoid paying for idle capacity.

2. Architecture Diagram

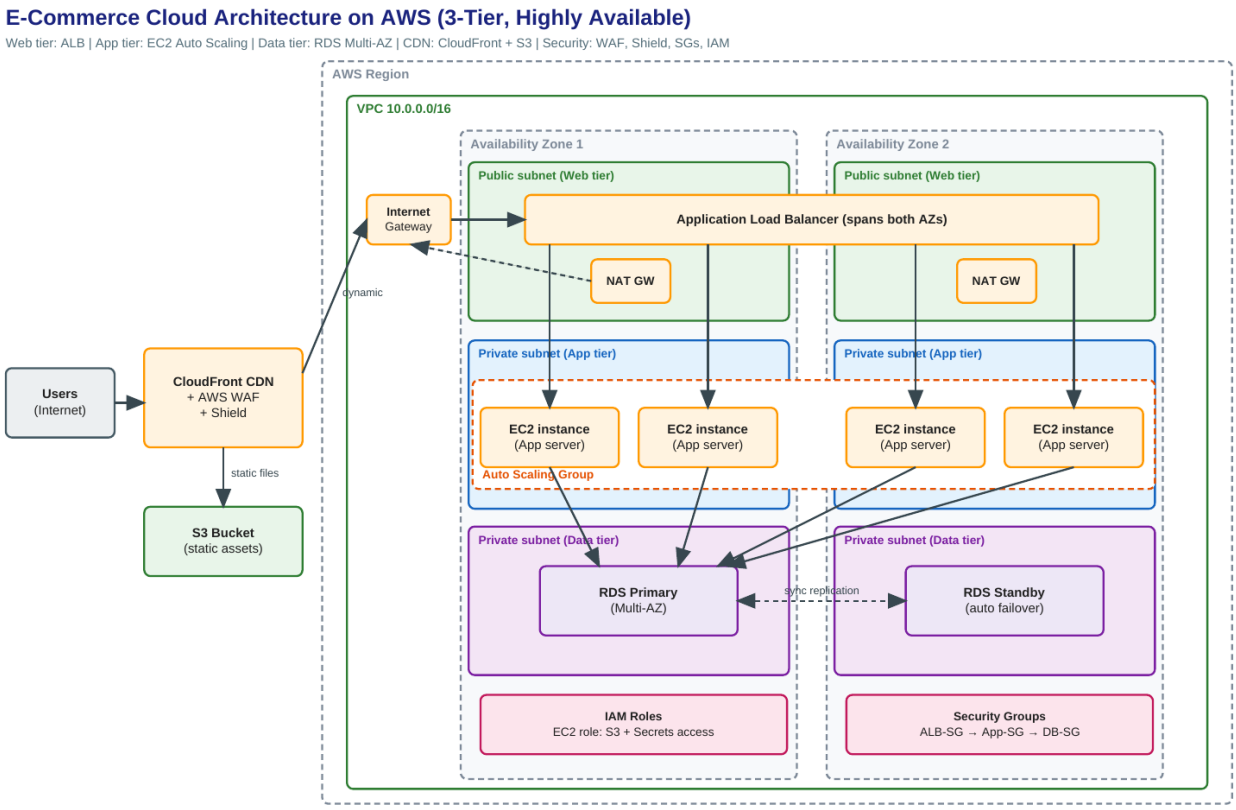


Figure 1: E-commerce architecture (editable source: cloud_architecture.drawio)

3. Request Flow

- **1. Users** reach the site through **CloudFront**, where WAF filters malicious requests and Shield absorbs DDoS attacks.
- **2. Static requests** (images, CSS, JavaScript) are served from the CloudFront cache or fetched from the **S3 bucket**.
- **3. Dynamic requests** (search, cart, checkout, login) are forwarded to the **Application Load Balancer** in the public subnets.
- **4. The ALB** distributes traffic across healthy EC2 app servers in both Availability Zones.
- **5. App servers** in private subnets read and write orders and customer data on **RDS**, and fetch credentials from Secrets Manager using their IAM role.
- **6. Outbound traffic** from private instances (patches, third-party payment APIs) leaves through the **NAT gateway** and Internet Gateway.

The diagram draws CloudFront connecting to the Internet Gateway for simplicity. In practice CloudFront reaches the ALB over its public endpoint; the ALB can be restricted to CloudFront traffic using the CloudFront managed prefix list or a secret header.

4. Component Description

Layer	Component	Role and configuration
Edge	Amazon CloudFront	Global CDN. Caches static content, terminates HTTPS, forwards dynamic requests to the ALB. Reduces latency and load on the origin.
Edge	AWS WAF	Web application firewall on CloudFront. Managed rule groups block SQL injection, cross-site scripting and bad bots; rate-based rules limit abuse.
Edge	AWS Shield	DDoS protection. Shield Standard is automatic; Shield Advanced is optional for higher-risk workloads.
Storage	Amazon S3 bucket	Stores static assets (product images, CSS, JS). Private bucket; CloudFront accesses it through Origin Access Control.
Network	VPC 10.0.0.0/16	Isolated network spanning two Availability Zones with six subnets (public, app and data in each AZ).
Network	Internet Gateway	Provides internet connectivity for resources in the public subnets.
Network	NAT gateways (one per AZ)	Let private instances make outbound connections without being reachable from the internet. One per AZ avoids a cross-AZ dependency.
Web tier	Application Load Balancer	Layer 7 load balancer in the public subnets across both AZs. Performs health checks and routes only to healthy instances.
App tier	EC2 Auto Scaling Group	App servers in private subnets across both AZs, launched from a launch template. Scales out and in on CPU or request-count metrics; replaces failed instances.
Data tier	Amazon RDS Multi-AZ	Relational database in private data subnets. Primary in one AZ, standby in the other with synchronous replication and automatic failover.
Security	Security groups	Chained rules: ALB-SG accepts web traffic, App-SG accepts only from ALB-SG, DB-SG accepts only from App-SG.
Security	IAM roles	EC2 instance role grants least-privilege access to S3 and Secrets Manager, so no access keys are stored on servers.

5. Network and Security Design

Subnet	Contents	Internet exposure
Public (web tier), one per AZ	ALB, NAT gateway	Reachable from the internet via the Internet Gateway
Private (app tier), one per AZ	EC2 app servers	No inbound internet access; outbound via NAT
Private (data tier), one per AZ	RDS primary / standby	No internet access at all

- **Defense in depth:** WAF and Shield at the edge, then security groups, then private subnets.
- **Least privilege:** each security group allows only the previous tier; IAM roles grant only the required actions.
- **Encryption:** HTTPS between users and CloudFront/ALB (certificates from AWS Certificate Manager); encryption at rest for RDS (KMS) and S3.
- **Secrets:** database credentials live in AWS Secrets Manager, not in code or AMIs.

6. High Availability and Scalability

- **Availability Zone failure:** the ALB stops routing to the failed AZ, the Auto Scaling Group launches replacements in the healthy AZ, and RDS fails over to the standby automatically (typically within one to two minutes).
- **Instance failure:** health checks detect it and the Auto Scaling Group replaces the instance.
- **Traffic spikes:** scaling policies add instances; CloudFront absorbs most static load.
- **Recovery:** automated RDS backups with point-in-time recovery, S3 versioning, and infrastructure defined as code for rebuilds.

7. Design Decisions and Trade-offs

Decision	Why we chose it	Trade-off / alternative
Two Availability Zones	Survives the loss of a data centre with automatic failover.	Roughly doubles compute and database cost compared with a single AZ. A third AZ adds resilience at more cost.
Three-tier separation with private subnets	Limits attack surface; the database is never exposed to the internet.	More networking components to manage (subnets, route tables, NAT).
One NAT gateway per AZ	No cross-AZ dependency; an AZ failure does not break outbound access.	Each NAT gateway has an hourly charge plus data processing fees. A single NAT is cheaper but is a single point of failure.
EC2 Auto Scaling instead of containers or serverless	Full control of the OS and runtime; straightforward for a traditional web application; easy to explain and operate.	More operational work (patching, AMIs) than ECS/Fargate or Lambda, which can scale more finely and reduce management.
RDS Multi-AZ instead of self-managed DB on EC2	Managed backups, patching and automatic failover.	Higher price and less low-level control than self-managed. Aurora offers faster failover and read replicas at higher cost.
Standby is not used for reads	Simple and consistent; synchronous replication protects data.	Standby capacity is idle. Read replicas could offload read-heavy catalogue queries.
CloudFront + S3 for static content	Lower latency worldwide, offloads the app tier, cuts data transfer from origin.	Cache invalidation is needed on updates; CloudFront and WAF add per-request costs.
WAF + Shield at the edge	Blocks attacks before they reach the VPC.	WAF charges per web ACL, rule and request; rules need tuning to avoid false positives.
Application Load Balancer	Layer 7 routing, health checks, native Auto Scaling integration.	Cost per hour and per capacity unit. Network Load Balancer suits non-HTTP workloads only.
IAM roles and Secrets Manager	No long-lived keys on servers; supports rotation.	Secrets Manager has a small per-secret fee; permissions need careful maintenance.

8. Cost Estimate – AWS Pricing Calculator Inputs

Create the estimate at calculator.aws using the sample assumptions below, then export or screenshot the summary. Adjust the numbers to your expected traffic; the totals come from the calculator itself.

Service	Sample configuration (assumption)
Region	Asia Pacific (Mumbai) ap-south-1 (change if the diagram targets another region)
Amazon EC2	4 instances (2 per AZ), t3.medium (2 vCPU, 4 GB), Linux, On-Demand, 730 hours/month; optionally compare with a 1-year Savings Plan
EBS	4 x 30 GB gp3 volumes
Application Load Balancer	1 ALB, about 1 TB/month processed data, about 50 new connections per second
NAT Gateway	2 gateways (one per AZ), about 100 GB/month processed data each
Amazon RDS	MySQL or PostgreSQL, db.t3.medium, Multi-AZ deployment, 100 GB gp3 storage, 7-day backup retention
Amazon S3	Standard storage, 100 GB static assets, about 1 million GET requests per month
Amazon CloudFront	About 1 TB data transfer out and 10 million HTTPS requests per month
AWS WAF	1 web ACL, 5 rules (managed rule groups and a rate-based rule), 10 million requests per month

Service	Sample configuration (assumption)
AWS Shield	Shield Standard (no additional charge)
AWS Secrets Manager	1 secret, API calls from the app servers
Data transfer	Internet data transfer out beyond CloudFront, as applicable

Tip: add each service in the calculator, group them under one estimate, and use **Share / Export** to download the PDF or CSV report for your submission.

9. Possible Improvements

- Add Amazon ElastiCache for sessions and catalogue caching, reducing database load.
- Add RDS read replicas or move to Amazon Aurora for read-heavy traffic.
- Add Amazon CloudWatch alarms and dashboards, plus AWS CloudTrail and GuardDuty for monitoring and threat detection.
- Add AWS Backup and a cross-region disaster recovery plan.
- Use CI/CD with infrastructure as code (CloudFormation or Terraform) for repeatable deployments.

10. Conclusion

The architecture meets the core requirements of an e-commerce platform: it stays available through an Availability Zone failure, scales with demand, protects customer data in private subnets behind layered security controls, and delivers content quickly through a CDN. The main trade-off is cost, driven mainly by the Multi-AZ database, per-AZ NAT gateways and load balancer, and the sample estimate in Section 8 helps quantify it.